7.1 CONTRAINTES TECHNIQUES & RÉGLEMENTAIRES

■ RÉALISÉ — MVP ■ CIBLÉ — PROD

CONTRAINTES TECHNIQUES

CONTRAINTE	EXIGENCE	IMPLÉMENTATION EPIPAY	STATUT
ARCHITECTURE MODULAIRE	Wallet, moteur IA et API inter-campus indépendants et évolutifs.	Expo Router modulaire par feature (`(wallet)`, `(shop)`, `admin`). Edge Functions Deno isolées : `federated-lookup`, `intercampus-send`, `intercampus-receive`, `fraud-scoring`.	RÉALISÉ
API REST JSON	Tous les échanges inter-campus utilisent un format JSON standardisé.	Contrat JSON documenté (Swagger) : `POST /lookup-user`, `POST /intercampus-receive`. Body normalisé (`api_key`, `email`, `amount`, `initiator_user_id`). Intégré avec 2 campus (Jordan, Toscan).	RÉALISÉ
PERFORMANCE	Analyse fraude < 300 ms ; système stable sans exigence 24/7.	Scoring IA léger côté edge function (règles métier + features). Latence mesurée 120–250 ms. Pas de SLA 24/7 (environnement de démo).	RÉALISÉ
BASE DE DONNÉES CENTRALE	Stockage unifié utilisateurs, transactions, alertes et logs.	Supabase Postgres (Frankfurt) : `profiles`, `transactions`, `intercampus_events`, `fraud_alerts`, `partner_campuses`. RLS activée sur toutes les tables.	RÉALISÉ
JOURNALISATION	Traçabilité complète des opérations et décisions.	Logs Supabase Edge Functions + métadonnées transaction (GPS, device, rules triggered). Table `fraud_alerts` stocke motif + score + décision.	RÉALISÉ
SÉPARATION DES RÔLES	Accès différencié étudiant / administrateur.	Routes séparées `app/(main)` (étudiant) vs `app/admin` (admin). Guard par `profiles.role` + policies RLS distinctes. Panel admin : fraude, métriques, produits, users.	RÉALISÉ
ACCESSIBILITÉ	Interface simple, claire, en français, conforme RGAA. Compatible navigateurs standards.	`AccessibilityProvider` global : 4 modes daltonisme (protan/deutan/tritan/achromat), texte agrandi, contraste élevé, reduce motion, texte gras. UI 100 % français. Préfs chiffrées (SecureStore).	RÉALISÉ

CONTRAINTES RÉGLEMENTAIRES

CONTRAINTE	EXIGENCE	IMPLÉMENTATION EPIPAY	STATUT
RGPD	Minimisation des données, pseudonymisation, accès restreints.	Écran consentement obligatoire (`consent.tsx`), privacy-policy intégrée, export données JSON, suppression compte avec anonymisation. Hébergement Supabase Frankfurt (UE). DPO : `dpo@epipay.epitech.digital`.	RÉALISÉ
TRAÇABILITÉ	Journalisation obligatoire des transactions et décisions IA.	Table `transactions` immuable (append-only) + `fraud_alerts` avec `rules_triggered`, `score`, `decision`. Conservation 5 ans (conforme DSP2).	RÉALISÉ
EXPLICABILITÉ	Chaque alerte IA doit fournir une justification compréhensible.	Composant `FraudAlert` affiche les règles déclenchées en langage naturel (ex : « Transaction > 500 EPC », « Device inconnu »). Score détaillé visible admin.	RÉALISÉ
DÉCISION HUMAINE	L'IA ne prend pas de décisions irréversibles.	Flow fraude = alerte + mise en quarantaine réversible. Admin valide ou rejette manuellement. Aucun blocage auto définitif. Export/delete compte : double confirmation user.	RÉALISÉ
SÉCURISATION DES ÉCHANGES	Échanges inter-campus authentifiés et conformes au JSON défini.	Clé API par campus partenaire (`api_key_hash` en BDD), HTTPS TLS 1.3, validation stricte du body. Auth utilisateur = JWT Supabase. Projection Prod : mTLS + rotation clés automatique.	PARTIEL